



Australian Government  
Australian Signals Directorate

**ASD** AUSTRALIAN  
SIGNALS  
DIRECTORATE  
**ACSC** Australian  
Cyber Security  
Centre



# IRAP Consumer Guide

July 2025

# Executive summary

## Purpose

The purpose of this document is to provide guidance for customers and consumers of Infosec Registered Assessors Program (IRAP) assessments and services.

## Intended audience

This document is intended for:

- consumers who are trying to engage an IRAP assessor for an IRAP assessment
- consumers managing an IRAP assessment, such as system owners, program managers and project managers
- decision makers who will use an IRAP assessment report as part of an authorisation package.

## Authority

This document represents the considered advice of the Australian Signals Directorate (ASD).

## IRAP objective

The objective of IRAP is to enhance Australia's cyber security posture by providing organisations access to highly-skilled cyber security professionals who can help inform their cyber risk assessments.

IRAP assessors provide independent quality assessments on the security of an organisation's systems and services to support consumer's decision making on whether to authorise a systems use.

# Table of contents

|                                                                    |    |
|--------------------------------------------------------------------|----|
| <b>Executive summary</b>                                           | 2  |
| Purpose                                                            | 2  |
| Intended audience                                                  | 2  |
| Authority                                                          | 2  |
| IRAP Objective                                                     | 2  |
| <b>Consumer guidance for IRAP</b>                                  | 4  |
| Infosec Registered Assessors Program                               | 4  |
| Value of IRAP                                                      | 4  |
| Government requirements                                            | 4  |
| IRAP assessors                                                     | 6  |
| Entity assessor vs IRAP assessor                                   | 6  |
| IRAP assessment outcomes                                           | 6  |
| <b>Engaging an IRAP assessor; preparing for an IRAP assessment</b> | 7  |
| Engaging an IRAP assessor                                          | 7  |
| Conflict of interest                                               | 7  |
| Preparing for an IRAP assessment                                   | 7  |
| <b>Consumer guidance on IRAP assessments</b>                       | 8  |
| IRAP assessment timeframes                                         | 8  |
| <b>Consumer guidance for post-IRAP assessment</b>                  | 9  |
| IRAP feedback                                                      | 9  |
| IRAP assessment report                                             | 9  |
| Authorisation package                                              | 9  |
| Multiple service providers                                         | 10 |
| Marketing an IRAP assessment                                       | 10 |
| <b>Appendix A</b>                                                  | 11 |
| IRAP RFQ Template                                                  | 11 |
| <b>Appendix B</b>                                                  | 12 |

# Consumer guidance for IRAP

## Infosec Registered Assessors Program

The Australian Signals Directorate (ASD), via the Infosec Registered Assessors Program (IRAP), provides organisations with access to high-quality, independent security assessment services using suitably qualified and endorsed cyber security professionals, known as IRAP assessors.

An IRAP assessor will:

- work to understand the system and the system owner's security requirements
- identify applicable controls from the [Information Security Manual](#) (ISM)
- assess the effectiveness of those controls, and
- provide an IRAP assessment report that outlines the system's security strengths and weaknesses, the outcomes of the controls assessment, and recommendations to improve the system's security posture.

A completed IRAP assessment does not imply that a system is compliant, endorsed or approved by ASD, or 'secure'. Rather, it is important for customers to read, determine the effectiveness of controls, and decide whether the residual security risks associated with operating the system are within their organisation's risk appetite.

**An IRAP assessor will not accredit, certify, endorse or register a system on behalf of ASD.**

## Value of IRAP

IRAP assessments are high-quality risk-based security assessments conducted by an IRAP assessor. They play a key role in an organisation's decision to authorise a system for use or operation. Specifically, they assist an authorising officer in identifying and understanding the security risks associated with the use of the system.

## Government requirements

The [Directive on Security of Government Business](#) establishes the [Protective Security Policy Framework](#) (PSPF) as Australian government policy. The PSPF is owned and developed by the Department of Home Affairs. Non-corporate Commonwealth entities that are subject to the [Public Governance, Performance and Accountability Act 2013](#) must apply the PSPF (to the extent consistent with legislation).

PSPF Table 21 (Table 1 within this guide) requires that SECRET, PROTECTED, OFFICIAL: Sensitive and OFFICIAL outsourced information technology and cloud services must be IRAP-assessed prior to processing and storing government data. In addition, PSPF 15.2 Secure Cloud Strategy requirement 0109 states that Cloud Service Providers must have had an IRAP assessment within the previous 24 months against the latest ISM at the time of assessment.

On-premises government systems at SECRET and below can have a security assessment conducted by either an entity assessor or an IRAP assessor. PSPF requirement 0086 requires that 'The Authorising Officer authorises each technology system to operate based on the acceptance of the residual security risks associated with its operation before that system processes, stores or communicates government information or data'.

A summary of the authorising officer, the security assessor, and the technology system to which they apply is provided at Table 1.

**Table 1 – Authorising Officer and Security Assessor for Technology System Authorisation**

| Technology System                                                                                                                | Security Assessor                                           | Authorising Officer                                                                                    |
|----------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| TOP SECRET systems (including sensitive compartmented information systems, outsourced information technology and cloud services) | Australian Signals Directorate assessor (or their delegate) | Director-General Australian Signals Directorate (or their delegate)                                    |
| SECRET system                                                                                                                    | Entity assessor or IRAP assessor                            | Accountable Authority or Chief Information Security Officer (or their delegate) of entity system owner |
| SECRET outsourced information technology and cloud services                                                                      | IRAP assessor                                               | Accountable Authority or Chief Information Security Officer (or their delegate) of entity system owner |
| PROTECTED, OFFICIAL: Sensitive and OFFICIAL systems                                                                              | Entity assessor or IRAP assessor                            | Accountable Authority or Chief Information Security Officer (or their delegate) of entity system owner |
| PROTECTED, OFFICIAL: Sensitive and OFFICIAL outsourced information technology and cloud services                                 | IRAP assessor                                               | Accountable Authority or Chief Information Security Officer (or their delegate) of entity system owner |
| Multinational and multi- entity systems                                                                                          | Determined by agreement between the parties involved        | Determined by a formal agreement between the parties involved                                          |
| Gateways                                                                                                                         | IRAP assessor                                               | Accountable Authority or Chief Information Security Officer (or their delegate) of entity system owner |

## IRAP assessors

Cyber security professionals endorsed by ASD as IRAP assessors must meet minimum pre-requisite requirements outlined in the IRAP Policy and Procedures. This ensures that the assessors have the appropriate skills and experience to provide IRAP services.

An IRAP assessor's experience may vary across a range of systems and environments. When engaging an IRAP assessor, consumers should seek adequate assurance that the assessor has the appropriate experience and knowledge to provide an effective assessment for the type of system or environment requiring assessment (e.g. cloud service, gateway, critical infrastructure).

IRAP assessors must ensure that they remain independent of the system or environment they are assessing. IRAP assessors cannot have contributed to the design and implementation of the system if they are to assess it. This includes drafting the system's documentation, conducting an initial gap assessment, providing design recommendations or having a material interest in the system (e.g. an IRAP assessor that works for a service provider cannot conduct IRAP assessment of their services, unless specifically hired for the purpose under contract).

In addition, IRAP assessors who are permanent employees of an organisation cannot conduct IRAP assessments for that organisation, regardless of the level of involvement in the design of the system.

IRAP assessors do not provide a recommendation on whether a system is suitable for authorisation as the IRAP assessment is required to be an independent process. Decisions to accept residual security risk and authorisation of the system to operate are the responsibility of the authorising officer.

IRAP assessors test the effectiveness of controls and identify security weaknesses. This helps inform the security risk picture for organisations. It is the responsibility of the authorising agency to determine the risks to their organisation associated with security weaknesses.

## Entity assessor vs IRAP assessor

An Entity assessor is someone who is employed or contracted on an ongoing basis to conduct security assessments of systems.

Entity assessors follow the procedures and processes defined by the organisation and are not bound by IRAP requirements, such as independence and adherence to the IRAP assessment process. There is no mandatory experience or skills requirements to be an entity assessor. It is up to the individual organisation to appoint an entity assessor that they deem suitable.

Conversely, IRAP assessors have demonstrated that they meet the skills and knowledge requirements set by ASD; including a combination of industry certifications, work experience, IRAP training and passing the IRAP exam. IRAP assessors conducting IRAP assessments must follow the IRAP policies, processes and procedures outlined by ASD.

If an IRAP assessor is unable to fulfill the independence requirements of IRAP, but they still conduct an assessment, they would be performing this function and assessment as an entity assessor rather than as an IRAP assessor.

## IRAP assessment outcomes

Consumers will receive an IRAP assessment report. This is based on the [IRAP assessment report templates](#) at the end of the assessment process.

They will also receive an assessment control matrix (a derivative of the [System Security Plan Annex Template](#)), which outlines an assessment of the implementation status of each applicable ISM control as well as a justification for that assessment.

**The IRAP assessment report outlines the findings of the assessment, including the system's security strengths and weaknesses. The system owner may develop a plan of action and milestones document to support the uplift of the system by detailing control recommendations. This can be used as part of an organisation's security program or uplift project.**

# Engaging an IRAP assessor; preparing for an IRAP assessment

## Engaging an IRAP assessor

ASD provides a comprehensive list of IRAP assessors. Although all IRAP assessors have met the standard as required by ASD, some may possess additional experience and expertise. This may make them more suitable to conduct an IRAP assessment on a specific system or environment.

Consumers seeking to engage an IRAP assessor should exercise due diligence during the hiring process. They should seek to ensure the IRAP assessor has the relevant experience and expertise to assess the system or environment in question.

**IRAP assessors must not agree to terms that would impede ASD's ability to review the assessment or evidence for quality assurance.**

## Conflict of interest

An IRAP assessor is required to maintain independence at all times and must not have been involved in any capacity in the design or development of the system being assessed.

IRAP assessors are required to complete a conflict of interest form at least 7 days prior to the commencement of an IRAP assessment. A conflict of interest form is submitted via ASD's [Partner Portal](#). IRAP assessors must outline and manage any perceived or actual conflicts of interest, and specify the mitigations that are in place.

Consumers should be aware of these requirements when engaging and working with an IRAP assessor.

More information on conflict of interest requirements for IRAP assessors can be found in the [IRAP Policy and Procedures](#).

## Preparing for an IRAP assessment

Planning for an IRAP assessment differs depending on the organisation type, structure and system.

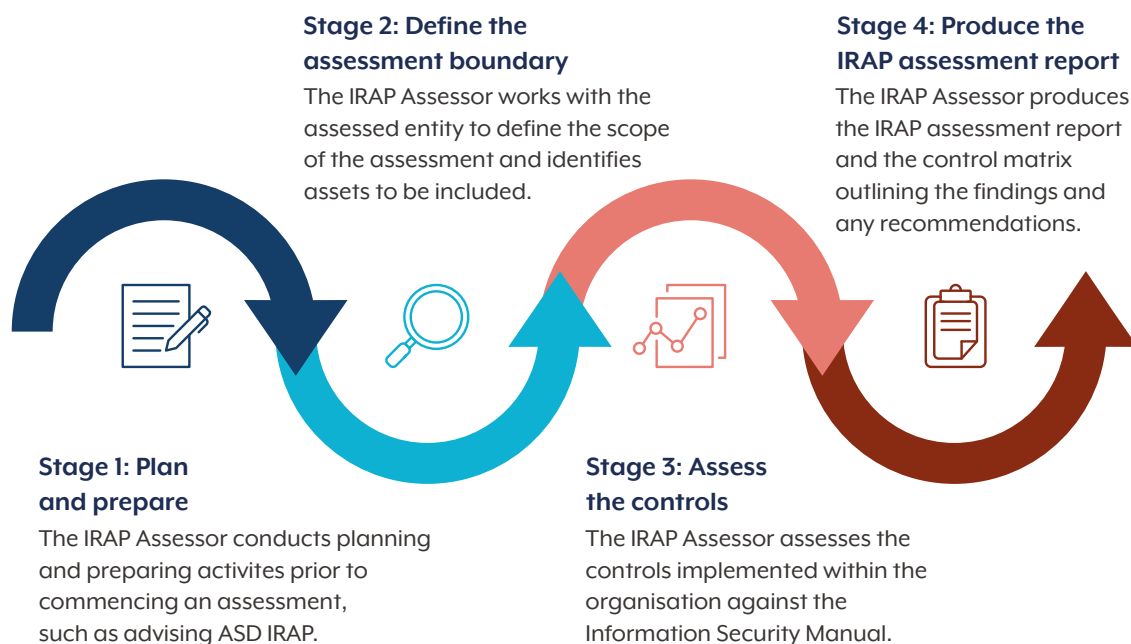
The following activities are recommended to allow for a smooth assessment

- Ensure that the required system documentation has been developed, is accurate and has been approved by the relevant authority. Documentation may include:
  - a security risk management plan
  - system design documents
  - a system security plan
  - a system security plan annex
  - a cyber security incident response plan
  - a continuous monitoring plan
  - the system security policies, processes and procedures.
- Ensure availability of relevant system personnel, such as the system owner, system administrators and security operations personnel, in order to support the assessment and evidence gathering.
- Where possible, begin to plan and collect evidence to support control assessments (request an initial list from the IRAP assessor, using the system security plan annex as a guide).
- Be prepared to provide any other relevant information that will provide additional context to the IRAP assessor, such as previous security assessment reports.

# Consumer guidance on IRAP assessments

During an IRAP assessment, the IRAP assessor will leverage several Australian Government frameworks, policies and guidelines, such as the [PSPF](#) and [ISM](#). IRAP assessors may consider additional frameworks as input for IRAP assessments, such as the Department of Home Affairs' [Hosting Certification Framework](#) certification reports and other physical security certification reports.

IRAP assessments include 4 key stages, as outlined in the [IRAP Common Assessment Framework](#):



During an IRAP assessment, and when determining control implementation and effectiveness, IRAP assessors will use the standardised assessment outcomes:

- **Effective** – The organisation is effectively meeting the control's objective
- **Ineffective** – The organisation is not adequately meeting the control's objective.
- **Alternate Control** – The organisation is effectively meeting the control's objective through an alternative control.
- **Not Assessed** – The control has not yet been assessed.
- **Not Applicable** – The control does not apply to the system or environment.
- **No Visibility** – The assessor was unable to obtain adequate visibility of a control's implementation.

## IRAP assessment timeframes

IRAP assessments vary in length based on several factors, including the size and scope of the assessment; the complexity of the system; the availability of key security personnel and evidence to support the assessment; and the assessor's familiarity with the type of organisation, environment and system under assessment.

To reduce the length of an IRAP assessment, thorough planning and preparation should be conducted beforehand by the organisation.



# Consumer guidance for post-IRAP assessment

## IRAP feedback

Consumers of IRAP services are encouraged to [submit feedback](#) about their experience with their IRAP assessor, the assessment process and the quality of the service.

## IRAP assessment report

An IRAP assessment report should provide an organisation with information relating to the security weaknesses associated with the use of a system. It should inform the authorisation decision and include:

- an overview of the system and types of environments; e.g. administration, test, development
- assessment details, including the assessment boundary
- the system's security strengths and weaknesses
- the governance arrangements
- the detailed findings, with supporting information and evidence
- the recommended remediation activities
- the completed assessment controls matrix as an annex.

IRAP assessors must use the [Cloud Security Report Template](#) or the [IRAP Assessment Report Template](#).

What is considered an acceptable level of risk for an organisation will differ depending on their objectives, culture and operating environment. Therefore, it is important to consider the information in an IRAP assessment report within the context of your organisation's objectives and risk tolerances. Likewise, it is important that IRAP assessment information is made available to other entities considering the use of your services to inform their risk-based decision-making.

When authorising a system, the authorising officer should seek an appropriate balance between system functionality and risk.

**IRAP assessors do not provide a recommendation to authorise, or not authorise, a system.** It is not the role of an IRAP assessor to determine the acceptable level of risk on behalf of the organisation.

## Authorisation package

The IRAP assessment report will form a key component of the authorisation package for a system. The authorisation package is the suite of reports and documents provided to the authorising officer to support their decision to authorise the system.

The authorisation package should be made available to other entities considering the service and consist of the following artefacts at a minimum:

- a system security plan
- a cyber security incident response plan
- a continuous monitoring plan
- a security assessment report (such as an IRAP assessment report)
- the assessment controls matrix
- a plan of action and milestones (if applicable).

## Multiple service providers

It is important to note that the authorisation package will vary depending on the nature of the management and ownership of a system. For example, if an organisation is looking to use a cloud service, it is likely that the cloud service provider has had an IRAP assessment of that service. The consuming organisation will therefore likely conduct an IRAP assessment covering aspects of the service for which they are responsible for designing, configuring or managing.

The following diagram shows the layered approach IRAP takes to support the authorisation decision.

### Layer 1 (Cloud Infrastructure Provider)

This IRAP assessment covers the infrastructure layer and the responsibilities of the cloud infrastructure provider in managing the infrastructure layer.

### Layer 2 (SaaS Provider)

This IRAP assessment covers the Software-as-a-Service (SaaS) layer and specifies the responsibilities of the SaaS provider. It should also have linkages to the infrastructure IRAP assessment by including key considerations provided within that layer's IRAP assessment report.

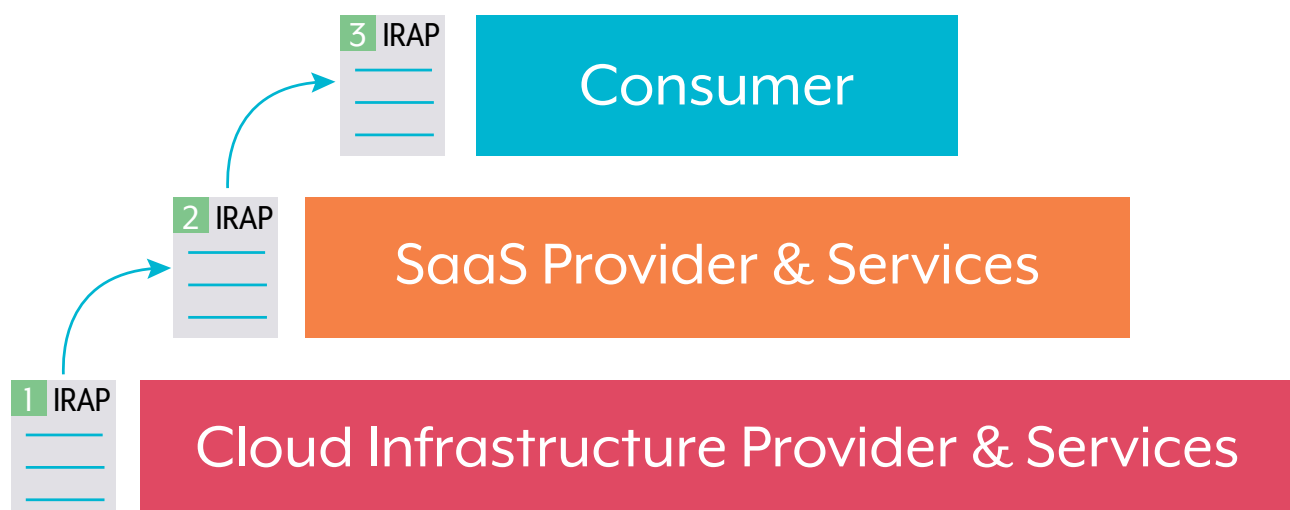
### Layer 3 (Consumer)

This IRAP assessment covers the security responsibilities of the consumer. It should also leverage the previous two layers' IRAP assessment reports to provide the relevant information to the authorising officer.

## Marketing an IRAP assessment

Service providers that have completed an IRAP assessment may want to advertise and market this. There are considerations needing to be observed to ensure that the marketing of the IRAP assessment aligns with the intent of the program:

- Here is an example of appropriate terminology: 'Organisation X has completed an IRAP assessment against the Information Security Manual's PROTECTED level controls.' The provider must also clearly list the specific services that have been assessed.
- Under no circumstances should service providers state or imply that their services or systems are certified, authorised or approved by, or compliant with:
  - ASD;
  - IRAP;
  - the Australian Government; and
- any level of Australian government data classification (e.g. PROTECTED)
- Service providers should make their IRAP assessment reports and controls matrix readily available to potential consumers to support their decision on whether or not to adopt their service(s). An assessment cover letter alone does not provide the potential consumer sufficient information to understand the security risks associated with consuming a service.



# Appendix A

## IRAP RFQ Template

The following template provides a typical fit-for-purpose Request for Quote (RFQ) that can be tailored as required when seeking to engage an IRAP assessor. This template should be adjusted to support any specific requirements.

[Insert Organisation Name] is seeking an IRAP assessor to conduct an IRAP assessment for our [Insert System Name]. The purpose of this IRAP assessment is to ensure security weaknesses are identified and understood to support the 'authority to operate' decision.

In accordance with IRAP requirements, the IRAP assessment must be independent and objective; provide an overview of the security posture of the system, including strengths, weaknesses and vulnerabilities stemming from control deficiencies; and provide recommendations to mitigate security weaknesses.

### Scope of work:

The IRAP assessor will be required to perform the following tasks:

- conduct a thorough and independent high-quality assessment in accordance with the IRAP Common Assessment Framework
- prepare a detailed report adhering to either the Cloud Security Report Template or the IRAP Assessment Report Template, per IRAP requirements
- provide an independent and objective view of the security posture of the system, including strengths, weaknesses and vulnerabilities
- identify security weaknesses associated with control deficiencies
- present clear and actionable recommendations to mitigate identified security weaknesses.

### Assessor requirements:

The IRAP assessor will be required to have:

- demonstrated expertise in conducting IRAP assessments for systems within [Insert Environment/System Type]
- relevant certifications related to cyber security and the [Insert Environment/ System Related Certification]
- proven experience and expertise in assessing systems similar to [Insert System Name] in size, complexity and sensitivity
- familiarity with Australian Government security frameworks, policies and guidelines
- strong communication and reporting skills to effectively convey findings and recommendations.

### Timeline and location:

- Estimated start date: [Insert Estimated Start Date]
- Initial contract duration: [Insert Initial Contract Duration]
- Extension term: [Insert Extension Term]
- Location of work: [Insert Location of Work]
- Security clearance required: [Insert Security Clearance Requirements].

### Submission of RFQ response:

Interested IRAP assessors are invited to submit their detailed RFQ response by [Insert Submission Deadline].

Responses should include the following:

- an overview of your experience and expertise in conducting IRAP assessments for systems similar to [System Name]
- details of relevant certifications and experience
- a proposed project plan including timelines and milestones
- the proposed team members and their experience
- a breakdown of the costs associated with the assessment
- any contact information for references from previous IRAP assessment customers (if available).

# Appendix B

ASD has provided consumers with a baseline checklist for preparing for an IRAP assessment. Consumers should consult with their engaged IRAP assessor for a more exhaustive list.

| Item no. | Item description                                                                                                                                                                                                                                                                                                                                                                                                                                   | Prepared |
|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| 1.       | Define assessment timelines (start / end dates and milestones) to be agreed with the IRAP assessor                                                                                                                                                                                                                                                                                                                                                 |          |
| 2.       | Define the scope of system and assessment boundary to be agreed and assessed by the IRAP assessor                                                                                                                                                                                                                                                                                                                                                  |          |
| 3.       | On-boarding requirements for the IRAP assessor (system access, facility access, clearance check or police checks)                                                                                                                                                                                                                                                                                                                                  |          |
| 4.       | Advise and schedule personnel to be available during the assessment period (system administrators, security personnel or system owners).                                                                                                                                                                                                                                                                                                           |          |
|          | Prepare documentation evidence, which may include:                                                                                                                                                                                                                                                                                                                                                                                                 |          |
|          | <ul style="list-style-type: none"> <li>• system security plan and annex</li> <li>• risk management documents</li> <li>• design and architectural documents</li> <li>• incident response plans and playbooks</li> <li>• organisational policies</li> </ul>                                                                                                                                                                                          |          |
| 5.       | <ul style="list-style-type: none"> <li>• standard operating procedures</li> <li>• security test cases and test plans</li> <li>• business continuity plans and disaster recovery plans</li> <li>• configuration and build documents</li> <li>• continuous monitoring plans</li> <li>• service provider security contract (extracts)</li> <li>• previous assessments or penetration tests conducted</li> <li>• hardening guidelines used.</li> </ul> |          |
|          | Prepare additional evidence, which may include:                                                                                                                                                                                                                                                                                                                                                                                                    |          |
|          | <ul style="list-style-type: none"> <li>• screenshots of system configurations, and cryptographic protocols and algorithms</li> </ul>                                                                                                                                                                                                                                                                                                               |          |
| 6.       | <ul style="list-style-type: none"> <li>• automated and manual testing of controls conducted</li> <li>• log files</li> <li>• vulnerability scan results and configurations</li> <li>• personnel prepared to conduct process or control demonstration</li> <li>• history of patching, testing of backup and restoration exercises.</li> </ul>                                                                                                        |          |

## Disclaimer

The material in this guide is of a general nature and should not be regarded as legal advice or relied on for assistance in any particular circumstance or emergency situation. In any important matter, you should seek appropriate independent professional advice in relation to your own circumstances.

The Commonwealth accepts no responsibility or liability for any damage, loss or expense incurred as a result of the reliance on information contained in this guide.

## Copyright

© Commonwealth of Australia 2025

With the exception of the Coat of Arms and where otherwise stated, all material presented in this publication is provided under a [Creative Commons Attribution 4.0 International licence](https://creativecommons.org/licenses/by/4.0/) | [creativecommons.org](https://creativecommons.org).

For the avoidance of doubt, this means this licence only applies to material as set out in this document.



The details of the relevant licence conditions are available on the Creative Commons website as is the [Legal Code for the CC BY 4.0 licence](https://creativecommons.org/licenses/by/4.0/) | [creativecommons.org](https://creativecommons.org).

## Use of the Coat of Arms

The terms under which the Coat of Arms can be used are detailed on the Department of the Prime Minister and Cabinet website [Commonwealth Coat of Arms Information and Guidelines](https://pmc.gov.au) | [pmc.gov.au](https://pmc.gov.au).

**For more information, or to report a cyber security incident, contact us:**

**cyber.gov.au | 1300 CYBER1 (1300 292 371)**

